
CLO # 1: Explain key concepts of information security such as design principles.

Q1 [5 marks]

- a) Explain the difference between active and passive attacks using Bob, Alice and Trudy analogy. [1 marks]

①

Solution:-

- **Passive:** Trudy only observes Alice–Bob communication (eavesdropping, no change).
- **Active:** Trudy modifies, deletes, or injects messages (impersonation, replay, modification).

- b) What is the confusion property in a good cryptosystem? How confusion is implemented in DES and AES algorithms? [2 marks]

②

Solution:-

Makes the relationship between the **ciphertext and key as complex as possible**, so an attacker cannot deduce the key from the ciphertext.

- **DES:** Achieved using **S-boxes** (nonlinear substitutions).
- **AES:** Achieved using **SubBytes step** with S-box substitutions on each byte.

- c) Suppose two adversaries: i) a small group of university students and ii) a cyberwarfare division of a country wants to guess the 46-bit shared key of a new encryption algorithm. Recommend and justify one approach for each group. Available options are either brute-force or cryptanalysis. [2 marks]

Solution:-

②

- **Students:** Use **brute-force**; 46-bit space ($\sim 7 \times 10^{13}$ keys) is small enough with GPUs or clusters
- **Cyberwarfare division:** Use **cryptanalysis**; with high resources, exploiting weaknesses is more efficient than exhaustive search.

CLO # 4: Identify appropriate techniques to tackle and solve problems of real life in the discipline of information security.

Q2 [5 marks]

- a) A university launches a secure online portal where students must log in using digital certificates. The university's IT department registers each student with a Certificate Authority (CA), which issues and signs their public-key certificates. Now, **illustrate** following two mechanisms:

①

- i) The process of secure creation of a student's certificate. [1 marks]

②

- ii) The process of verification of a certificate by the portal? [2 marks]

Solution:-

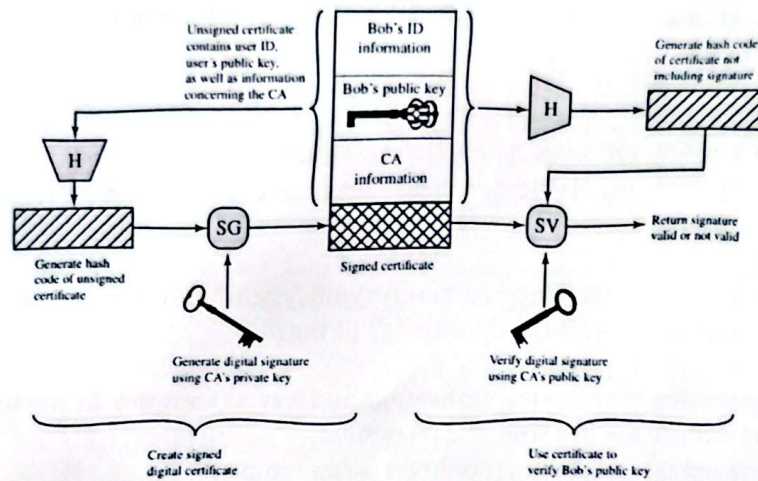
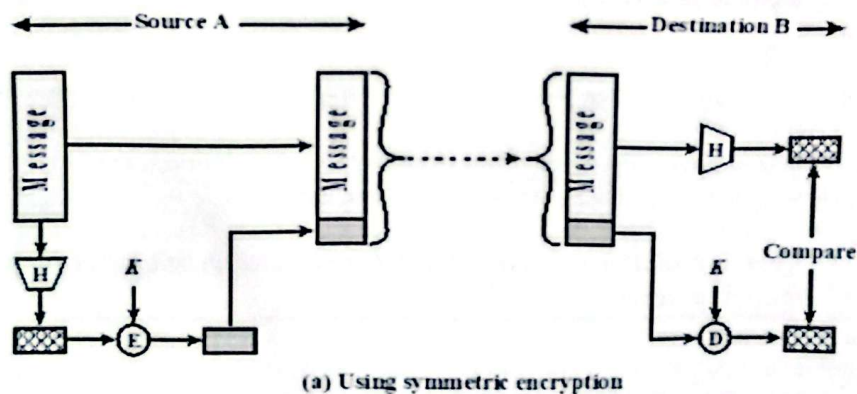


Figure 2.8 Public-Key Certificate Use

- 2) b) A company wants to ensure that files downloaded by its clients are authentic, unaltered, and traceable to the sender. **Illustrate a method that uses symmetric encryption and hash function only. Ignore certificates. [2 marks]**

Solution:-



CLO # 3: Analyze and apply various security and risk management tools for achieving information security and privacy.

Q3 [5 marks]

- a) Layering is required in case of defense-in-depth policy. If AES provides strong confidentiality, name one other security layer (technical or non-technical) that is essential to protect the encrypted data, and explain why. [1 marks]

Solution:-

Even with AES, **access control** is essential to prevent unauthorized users from accessing the decryption key or ciphertext, ensuring the data remains confidential.

- b) A university deploys an online examination system that must address threats such as cheating, denial-of-service, and data tampering. Identify two CIA triad components that are most critical for this system, and explain why. [2 marks]

Solution:-

①
②

- **Integrity:** Critical to prevent tampering with questions, answers, or results.
- **Availability:** Essential to keep the exam system running; denial-of-service would stop students from completing exams.

- c) An attacker finds two different files producing the same hash value. Which property of hash functions is broken, and what real-world consequences could arise? [2 marks]

Solution:-

Property broken: Collision resistance – two different inputs produce the same hash.

Consequence: An attacker could substitute a **malicious file** for a legitimate one (e.g., software update, exam paper, contract) while keeping the same hash, bypassing verification and causing security breaches.

②